TP2 : DÉPLOYER ET ADMINISTRER UNE PKI AD CS

Formation : Implémenter une PKI avec Microsoft AD CS - Jour 2 - **Dates** : 20 et 21/10/2026

Réalisé par : Landry TOUOTAP

Tickets : CHG-2026-042, INC-2026-118, SEC-2026-021, SEC-2026-027

1. Contexte et résultat

L'autorité d'entreprise **ALPINA-LAB-CA** est opérationnelle dans le domaine de laboratoire pki.lab : elle délivre un modèle de poste réservé au groupe **ALPINA-PKI-Pilote**, distribué par auto-inscription, et la révocation d'un certificat compromis est publiée et vérifiée sur le client. Un poste hors du groupe pilote est refusé (0x80094012).

Aucun laboratoire n'était fourni : je l'ai construit sous VMware Workstation, sur un réseau virtuel isolé (VMnet1, host-only, sans DHCP), avec des ISO d'évaluation Windows Server 2025 et Windows 11 Entreprise.

Machine	Système	Adresse IP	DNS	Rôle
SRV-DC01	Windows Server 2025 (Expérience utilisateur)	192.168.178.10	127.0.0.1	AD DS + DNS, forêt pki.lab (NetBIOS PKI)
SRV-CA01	Windows Server 2025 (Expérience utilisateur)	192.168.178.11	192.168.178.10	AD CS, Enterprise Root CA
CLIENT01	Windows 11 Entreprise	192.168.178.21	192.168.178.10	Poste autorisé (groupe pilote)
CLIENT-TEST	Windows 11 Entreprise	192.168.178.22	192.168.178.10	Poste non autorisé (défi RSSI)

Captures : captures\A0_vmnet1.png ; captures\Carte_reseau_SRV_DC01.png ; captures\A0_DC01_ip.png ; captures\A0_DC01_domaine.png

2. Mission A : audit des prérequis

Les trois prérequis critiques sont validés sur chaque membre : résolution DNS du DC, port LDAP 389 joignable, et heure synchronisée sur SRV-DC01.pki.lab.

Contrôle	SRV-CA01	CLIENT01
Domaine / compte	pki.lab / pki\administrateur	pki.lab / pki\administrateur
Resolve-DnsName srv-dc01.pki.lab	192.168.178.10	192.168.178.10
Test-NetConnection … -Port 389	True	True (port 53 également)
w32tm /query /source	SRV-DC01.pki.lab	SRV-DC01.pki.lab

CLIENT-TEST, ajouté pour le défi RSSI, a été configuré de la même façon et joint au domaine directement dans OU=Postes-Lab.

Deux incidents d'audit ont été rencontrés et corrigés : un premier test de résolution DNS de CLIENT01 a expiré car l'adresse IP était encore à l'état Tentative (test du port 53 réussi quelques secondes après) ; sur SRV-CA01, la première session était ouverte avec le compte local srv-ca01\administrateur, insuffisant pour installer une AC d'entreprise ; la reconnexion en PKI\Administrateur a confirmé l'appartenance aux **Administrateurs de l'entreprise** (SID se terminant par -519).

Captures : captures\A1_audit_CA01.png ; captures\A1_audit_CLIENT01.png ; captures\A1_audit_CLIENT01_domaine.png

Schéma d'architecture

Le schéma TP2_architecture_PKI.png (source TP2_architecture_PKI.drawio) représente les quatre VM, le DNS, les flux d'inscription (autorisé et refusé) et la vérification de la CRL.

Capture : captures\TP2_architecture_PKI.png

Trois risques si un prérequis est défaillant

Prérequis	Risque
DNS	Les membres ne trouvent ni le DC (enregistrements SRV) ni l'AC : jonction au domaine, lecture des modèles et des GPO, inscription et téléchargement des CRL échouent.
Horloge	Au-delà de 5 minutes d'écart, Kerberos refuse l'authentification : plus d'inscription. Un certificat ou une CRL peut aussi paraître « pas encore valide » ou expiré.
Permissions d'inscription	Trop larges : des machines non prévues obtiennent un certificat d'authentification (cas du défi RSSI). Trop restreintes : les postes légitimes n'obtiennent rien (cas de l'incident INC-2026-118).

Types d'autorité de certification

Type	Caractéristiques	Usage
Enterprise Root CA	Racine autosignée, membre du domaine, intégrée à AD : modèles, auto-inscription, publication automatique dans l'annuaire	Laboratoire ou très petite structure (choix du TP)
Standalone Root CA	Racine autosignée, sans dépendance à AD, pas de modèles ; peut rester éteinte et hors réseau	Racine hors ligne d'une PKI à deux niveaux
Enterprise Subordinate CA	Certificat signé par une racine, intégrée à AD avec modèles et auto-inscription	AC émettrice au quotidien sous une racine hors ligne

3. Mission B : installation et contrôle de l'AC

L'AC a été installée avec Install-AdcsCertificationAuthority (ErrorId 0). Un contrôle ultérieur a montré que le rôle et le service CertSvc étaient déjà actifs : conformément à la consigne, l'AC n'a pas été réinstallée, elle a été contrôlée et documentée.

Élément	Valeur relevée
Type (certutil -getreg CA\CAType)	0 = ENUM_ENTERPRISE_ROOTCA
certutil -ping	Interface ICertRequest d'ALPINA-LAB-CA active (78 ms)
Subject = Issuer	CN=ALPINA-LAB-CA, DC=pki, DC=lab (racine autosignée)
Validité	du 21/10/2026 11:02:33 au 21/10/2031 11:12:20 (5 ans)
Thumbprint	B6C950D2A40F13D9667E6DAE46ED98F5C36B9F3A
Clé / signature	RSA 3072 bits (Microsoft Software KSP) / sha256RSA
Extensions	Basic Constraints CA=TRUE (critique), Key Usage : signature de certificats et de CRL
CRLPublicationURLs	dossier local CertEnroll + LDAP (seule adresse inscrite dans les certificats) ; HTTP et file non configurés

Le début de validité est antérieur de 10 minutes à la création : AD CS antidate le certificat pour tolérer un léger décalage d'horloge.

Pourquoi choisir le nom et la hiérarchie avant l'installation : le nom de l'AC est inscrit dans le champ Issuer de chaque certificat émis, dans les chemins CDP/AIA et dans l'annuaire ; le type d'AC est figé à l'installation. Changer l'un ou l'autre impose de reconstruire l'AC et de réémettre tous les certificats.

Captures : captures\B1_verification_avant_install.png ; captures\B2_installation_AC.png ; captures\B1_AC_existante.png ; captures\B3_certutil_ping.png ; captures\B3_certificat_AC1.png ; captures\B3_certificat_AC2.png ; captures\B4_console_certsrv1.png ; captures\B4_console_certsrv2.png

4. Mission C : modèle ALPINA-Postes-Lab et inscription manuelle

Le modèle est réservé au groupe ALPINA-PKI-Pilote (OU Postes-Lab, CLIENT01 seul membre) et son identité est imposée par l'annuaire.

Paramètre	Valeur	Justification
Base	Duplicata du modèle « Ordinateur »	Usages adaptés à un poste
Compatibilité	AC Windows Server 2016 / destinataire Windows 10	Débloque le fournisseur KSP ; à l'origine, le niveau hérité grisait ce choix
Validité / renouvellement	1 an / 6 semaines	Durée courte pour un certificat de poste
Chiffrement	Fournisseur de stockage de clés, RSA 2048, SHA256	API CNG moderne, stockage TPM possible
Exportation de la clé privée	Interdite	La clé ne quitte pas le poste
Nom du sujet	Construit à partir d'AD (nom commun + DNS)	Empêche un demandeur de choisir l'identité (ESC1)
EKU	Authentification du serveur et du client	Hérités du modèle Ordinateur
ACL	Ordinateurs du domaine supprimé ; ALPINA-PKI-Pilote : Lecture + Inscrire (+ Inscription automatique en mission D)	Moindre privilège

dsacls sur l'objet du modèle confirme : Enroll pour ALPINA-PKI-Pilote, Admins du domaine et Administrateurs de l'entreprise ; aucune entrée pour Ordinateurs du domaine. Après publication, certutil -CATemplates affiche ALPINA-Postes-Lab -- Inscription automatique : Accès refusé pour le compte administrateur, ce qui est attendu. La publication depuis certsrv.msc a d'abord échoué ; le modèle a ensuite été publié et sa présence vérifiée avec certutil -CATemplates.

Captures : captures\C1_groupe_pilote.png ; captures\C2_modele_general.png ; captures\C2_modele_nom_sujet.png ; captures\C2_modele_ACL.png ; captures\C2_dsacls_modele.png ; captures\C3_modeles_publies.png ; captures\C3_certutil_catemplates.png

Inscription manuelle (certlm.msc, 13:25) : CLIENT01 voit l'AC dans le magasin racine Entreprise (distribuée par AD) et obtient le certificat CN=CLIENT01.pki.lab, émis par ALPINA-LAB-CA, SAN CLIENT01.pki.lab, EKU authentification serveur et client, empreinte EB9CDE66E024BFA4D3799E10124FB78CCE1DDD37.

Écart détecté : ce premier certificat expirait le 20/10/2028 (2 ans) au lieu d'un an ; la période de validité du modèle a été corrigée, les certificats suivants expirent bien au bout d'un an.

Captures : captures\C4_client_groupe_confiance.png ; captures\C4_demande_certificat.png ; captures\C4_inscription_reussie.png ; captures\C4_certificat_obtenu.png

5. Mission D : auto-inscription et incident INC-2026-118

Le certificat manuel a été exporté sans clé privée (poste-test.cer) puis retiré du magasin pour reproduire le symptôme. Deux corrections ont rétabli l'auto-inscription.

Étape	Constat
Symptôme	Après certutil -pulse, aucun certificat ALPINA dans Cert:\LocalMachine\My de CLIENT01
Hypothèses	1. Aucune GPO n'active l'auto-inscription ; 2. le groupe pilote n'a pas le droit Inscription automatique
Observation / preuve	gpresult /r : seule la Default Domain Policy ; CLIENT01 bien membre d'ALPINA-PKI-Pilote et dans OU=Postes-Lab ; ACL du modèle : Lecture + Inscrire seulement
Correction	Droit Inscription automatique au groupe pilote ; GPO GPO-PKI-AutoEnroll-Postes liée à OU=Postes-Lab : Client des services de certificats – Inscription automatique activé, renouvellement et mise à jour cochés
Résultat	gpupdate /force : nouveau certificat à 14:28, empreinte 04C7145971648839537CB916AC7E14CAF8F1F08E, valable jusqu'au 21/10/2027 ; événement 1006 dans CertificateServicesClient-Lifecycle-System/Operational

Manuel ou automatique : l'inscription manuelle nécessite le seul droit Inscrire et une action de l'administrateur sur le poste ; l'auto-inscription exige en plus le droit Inscription automatique et une GPO, puis le poste obtient et renouvelle

seul son certificat (déclenchée ici dès le gpupdate). Les réussites ne sont pas journalisées dans le journal Application par défaut : il faut lire le journal Lifecycle-System.

Captures : captures\D1_symptome_pas_de_certificat.png ; captures\D1_gpresult_avant1.png ; captures\D1_gpresult_avant2.png ; captures\D2_ACL_autoenroll.png ; captures\D3_GPO_autoenroll.png ; captures\D3_GPO_liaison.png ; captures\D4_gpresult_apres.png ; captures\D4_certificat_auto.png ; captures\D4_journal_autoenroll.png ; captures\D4_certificats_delivres.png

6. Mission E : révocation et CRL (SEC-2026-021)

Le certificat de test EB9CDE66… (série 7400000003ad4b2ba63bd7d9cd000000000003) a été révoqué avec le motif **Compromission de la clé** ; après publication d'une nouvelle CRL et purge du cache, CLIENT01 le déclare révoqué.

Vérification sur CLIENT01	CRL utilisée	Résultat
Avant publication (certutil -urlfetch -verify poste-test.cer)	ThisUpdate 21/10/2026 11:02 (CRL initiale), NextUpdate 28/10/2026	Vérification de révocation réussie : le certificat paraît valide
Après certutil -crl sur la CA et certutil -urlcache crl delete sur le client	ThisUpdate 21/10/2026 15:21 (nouvelle CRL)	CRYPT_E_REVOKED 0x80092010, « certificat feuille révoqué (Raison=1) »

URL CDP du certificat : une seule, ldap:///CN=ALPINA-LAB-CA,CN=SRV-CA01,CN=CDP,CN=Public Key Services,…. Aucune URL HTTP n'a été configurée : seules les machines du domaine peuvent télécharger la CRL. **Limite du laboratoire** : ce test ne prouve pas que la diffusion fonctionnerait pour un poste hors domaine ou en production.

Pourquoi la révocation n'est pas immédiate : le client ne l'apprend qu'en lisant une CRL publiée après la révocation. Tant que la date NextUpdate de la CRL en cache n'est pas atteinte (ici 7 jours pour la CRL de base, environ un jour et demi pour la delta), il ne la retélécharge pas. La disponibilité du point de publication (LDAP ou HTTP) conditionne aussi la vérification.

Captures : captures\E1_certificat_a_revoquer.png ; captures\E1_revocation_motif.png ; captures\E1_certificats_revoques.png ; captures\E2_publication_crl.png ; captures\E2_publication_crl_after.png ; captures\E2_contenu_crl.png ; captures\E3_cdp_certificat.png ; captures\E3_verification_revocation1.png ; captures\E3_verification_revocation2.png (avant publication) ; captures\E3_verification_revocation_after.png ; captures\E3_verification_revocation_after2.png (après)

7. Défi RSSI : moindre privilège (SEC-2026-027)

Un poste hors du groupe pilote ne peut pas obtenir le certificat : CLIENT-TEST est refusé, CLIENT01 réussit avec la même commande, le même modèle, la même OU et la même GPO.

1. Droits et groupes, prédiction

Poste	OU	Groupes	GPO d'auto-inscription	Prédiction
CLIENT01	Postes-Lab	ALPINA-PKI-Pilote, Ordinateurs du domaine	appliquée	certificat obtenu
CLIENT-TEST	Postes-Lab	Ordinateurs du domaine uniquement	appliquée	refus

ACL du modèle : ALPINA-PKI-Pilote = Lecture, Inscrire, Inscription automatique ; Utilisateurs authentifiés = Lecture ; Ordinateurs du domaine = aucune entrée. CLIENT-TEST peut donc lire le modèle mais pas s'y inscrire.

2-3. Tests légitimes avec les outils Windows

Test	CLIENT-TEST (non autorisé)	CLIENT01 (autorisé)
Auto-inscription (gpupdate, certutil -pulse)	aucun certificat, malgré la GPO appliquée	certificat obtenu (mission D)
certlm.msc (Afficher tous les modèles)	modèle « Non disponible »	modèle proposé
certreq -enroll -q -machine ALPINA-Postes-Lab	0x80094012 CERTSRV_E_TEMPLATE_DENIED, aucun ID de demande	« Le certificat demandé a été émis », RequestId 6, empreinte CC5413F2…

Diagnostic : la GPO s'applique aux deux postes et l'AC répond (CLIENT01 est servi), donc ni l'absence de GPO, ni un modèle non publié, ni une CA indisponible ne peuvent expliquer le refus. Seule l'appartenance au groupe diffère : le refus vient de l'ACL du modèle. Il intervient côté client, avant tout envoi à l'AC, ce que confirme le dossier « Demandes ayant échoué » de l'AC, resté vide.

4. Les deux postes n'étaient pas autorisés par erreur : aucune correction n'a été nécessaire. La restriction a été posée en amont, en mission C, en supprimant Ordinateurs du domaine, hérité du modèle Ordinateur. Sans cette suppression, CLIENT-TEST, membre d'Ordinateurs du domaine, aurait obtenu le certificat.

Captures : captures\R1_groupes_postes.png ; captures\R1_ACL_modele.png ; captures\R2_CLIENT-TEST_gpresult.png ; captures\R2_CLIENT-TEST_refus_certreq.png ; captures\R2_CLIENT-TEST_certlm_non_disponible.png ; captures\R3_CLIENT01_autorise.png ; captures\R3_demandes_echouees.png

5. Moindre privilège et ESC1

Un certificat d'authentification client vaut une identité dans le domaine : avec lui, on ouvre une session Kerberos (PKINIT) au nom de l'objet désigné dans le certificat. Si un modèle portant cet usage laisse le demandeur fournir le SAN (« Fournir dans la demande ») et que des groupes larges peuvent s'y inscrire, n'importe quel utilisateur peut demander un certificat au nom d'un administrateur du domaine et s'authentifier en tant que lui : c'est la faille **ESC1**. Le moindre privilège limite qui peut s'inscrire, et l'identité construite depuis AD empêche de choisir au nom de qui. Les deux protections sont en place sur ALPINA-Postes-Lab.

Recommandations du RSSI

- Retirer le droit Inscrire aux Admins du domaine et Administrateurs de l'entreprise sur ce modèle : ils n'ont pas besoin d'un certificat de poste, et un administrateur pourrait aujourd'hui en demander un hors du groupe pilote.
- Ne jamais combiner « Fournir dans la demande », un EKU d'authentification et des droits d'inscription larges ; activer « Approbation du gestionnaire de certificats » sur les modèles sensibles.
- Revoir périodiquement les ACL des modèles et les membres des groupes autorisés.

Question bonus, contrôle préventif automatisé : activer l'audit de la CA (certutil -setreg CA\AuditFilter 127) et la stratégie d'audit « Services de certificats », puis remonter dans un SIEM les événements 4899 (modèle modifié) et 4900 (sécurité d'un modèle modifiée), ainsi que les événements 5136 (modification d'objet AD) sur le conteneur CN=Certificate Templates ; compléter par un scan planifié (Locksmith, PingCastle) qui compare les ACL et les drapeaux des modèles à une référence et alerte en cas d'écart.

8. Questions d'analyse

Question	Réponse
Pourquoi un client peut-il recevoir un certificat alors qu'il ne devrait pas ?	Droits hérités trop larges (Ordinateurs du domaine sur un duplicata d'« Ordinateur »), groupe autorisé trop large, SAN fourni par le demandeur, ou administrateur disposant du droit Inscrire.
Différence entre le certificat de l'AC et le modèle ?	Le certificat de l'AC est son identité cryptographique (clé publique, stockée sur la CA). Le modèle est une règle d'émission stockée dans AD : qui peut demander, quelle identité, quels usages, quelle durée.
Que se passe-t-il si la CA est approuvée mais la CRL inaccessible ?	Le client ne peut pas conclure sur la révocation (CRYPT_E_REVOCATION_OFFLINE) : selon l'application, il rejette le certificat (interruption de service) ou l'accepte sans contrôle (un certificat révoqué reste utilisable).
Pourquoi la racine hors ligne ne doit-elle pas émettre au quotidien ?	Émettre exige qu'elle soit allumée et en réseau, ce qui expose la clé dont dépend toute la confiance. Sa compromission obligerait à remplacer la racine sur tous les postes, alors qu'une AC émettrice compromise se révoque depuis la racine.
Quelles mesures réduisent l'abus des modèles ?	Droits Enroll limités à des groupes dédiés, identité construite depuis AD, EKU minimaux, approbation du gestionnaire pour les modèles sensibles, administrateurs PKI séparés et peu nombreux, audit des modifications.

9. Note d'architecture : passage à une PKI à deux niveaux

Je recommande de remplacer l'AC racine d'entreprise du laboratoire par une hiérarchie à deux niveaux. Une **Root CA autonome hors ligne** (hors domaine, éteinte, clé idéalement en HSM, validité 10 à 20 ans) ne signe que le certificat de l'AC émettrice et sa propre CRL, publiée tous les 6 à 12 mois lors d'une cérémonie documentée. Une **Issuing CA d'entreprise** jointe au domaine (validité 5 ans) porte les modèles, l'auto-inscription et les émissions quotidiennes.

Les points **CDP et AIA** doivent être publiés en **HTTP** sur un serveur dédié (par exemple http://pki.alpina.test/CertEnroll/), en plus de LDAP, et inscrits dans les certificats avant toute émission, pour que tous les clients, y compris hors domaine, vérifient la chaîne et la révocation. Le certificat de la racine est distribué par GPO. On ajoute des CRL delta fréquentes ou un répondeur OCSP pour réduire le délai de prise en compte d'une révocation. Si l'AC émettrice est compromise, on la révoque depuis la racine et on la reconstruit sans toucher à la confiance installée sur les 450 postes.

10. Procédure de dépannage en cas d'échec d'inscription

Symptôme	Hypothèse	Test	Remédiation
Modèle absent de certlm.msc ou refus 0x80094012	Le poste n'a pas Inscrire sur le modèle	ACL du modèle (dsacls), gpresult /r (groupes de la machine)	Ajouter le poste au groupe autorisé, puis redémarrer le poste
Membre du groupe mais toujours refusé	Ticket Kerberos antérieur à l'ajout au groupe	gpresult /r /scope computer ne liste pas le groupe	Redémarrer le poste (ou purger les tickets machine)
Aucun certificat automatique	GPO absente ou droit Inscription automatique manquant	gpresult /r, ACL du modèle, certutil -pulse	Lier la GPO à l'OU du poste, accorder Inscription automatique
Modèle non proposé alors que les droits sont bons	Modèle non publié sur l'AC	certutil -CATemplates	Publier le modèle, redémarrer CertSvc si besoin
Échec de contact avec l'AC	AC arrêtée, DNS ou réseau	certutil -ping, Resolve-DnsName, Test-NetConnection	Démarrer CertSvc, corriger DNS ou pare-feu
Échec d'authentification	Écart d'horloge > 5 min	w32tm /query /status	w32tm /resync, vérifier la source NTP du DC

Symptôme	Hypothèse	Test	Remédiation
Certificat révoqué encore accepté	CRL en cache	certutil -urlfetch -verify : date ThisUpdate	certutil -crl sur la CA, certutil -urlcache crl delete sur le client
Échec silencieux	Journalisation des réussites désactivée	Journal Application (erreurs) et Lifecycle-System (événement 1006)	Analyser le code d'erreur avant de modifier la configuration

11. Trame de la restitution (3 minutes)

Temps	Contenu
0:00 – 0:40	**Architecture** : quatre VM isolées, AC racine d'entreprise ALPINA-LAB-CA (choix de laboratoire), schéma
0:40 – 1:30	**Réussite** : modèle restreint au groupe pilote, auto-inscription par GPO, révocation vue par le client (CRYPT_E_REVOKED)
1:30 – 2:20	**Incident** : poste sans certificat (pas de GPO, pas de droit Autoenroll) ; défi RSSI : CLIENT-TEST refusé 0x80094012, CLIENT01 servi
2:20 – 3:00	**Recommandations** : racine hors ligne + AC émettrice, CDP/AIA en HTTP, retrait du droit Inscrire aux administrateurs, audit des modèles

Les captures citées se trouvent dans le dossier captures du dépôt. Aucun compte administrateur ni certificat avec clé privée n'est remis.